

CYB-045 : Gestion des incidents et réponse aux attaques

Introduction Générale du Cours

Une cyberattaque réussie n'est pas une fatalité, mais l'absence de réponse organisée, elle, est une erreur de gouvernance. Entre le moment où un attaquant pénètre dans un système d'information et le moment où il atteint son objectif — chiffrement des données, exfiltration, sabotage — il s'écoule en moyenne plusieurs heures, parfois plusieurs jours ou semaines dans le cas d'attaques APT. Ce délai est une fenêtre d'opportunité pour le défenseur : une organisation capable de détecter rapidement une intrusion et d'y répondre de manière structurée peut interrompre la chaîne d'attaque avant que les dommages ne deviennent irréversibles.

La gestion des incidents de sécurité est la discipline qui transforme cette fenêtre d'opportunité en avantage défensif concret. Elle repose sur une méthodologie rigoureuse — détecter, analyser, confiner, éradiquer, rétablir, capitaliser — appliquée par des équipes formées, équipées d'outils adaptés et guidées par des processus documentés. Sans cette méthodologie, même les meilleures technologies de détection restent inefficaces : une alerte non traitée selon un processus clair ne protège personne.

Ce cours explore en profondeur chacune des phases du cycle de réponse à incident, depuis la préparation en amont jusqu'au retour d'expérience post-incident. Nous aborderons les techniques d'analyse forensique numérique permettant de reconstituer la chronologie d'une attaque, les stratégies de confinement adaptées à chaque type de menace, les procédures de rétablissement garantissant un retour à un état sécurisé, et les obligations légales de notification qui s'imposent aux organisations lors d'incidents affectant des données personnelles ou des infrastructures critiques.

Objectifs Pédagogiques du Module

À l'issue de ce cours, l'apprenant doit être capable de :

1. Maîtrise Conceptuelle et Méthodologique

- Comprendre et appliquer les six phases du cycle de réponse à incident (PICERF : Préparation, Identification, Confinement, Éradication, Rétablissement, Feedback).
- Distinguer les différentes catégories d'incidents de sécurité et leurs niveaux de criticité.
- Positionner la gestion des incidents dans le cadre réglementaire applicable (RGPD, NIS2, DORA).

2. Compétences Techniques et Opérationnelles

- Appliquer une méthodologie de détection et d'analyse pour qualifier un incident de sécurité.

- Collecter et préserver des artefacts forensiques dans le respect de la chaîne de custody.
- Mettre en œuvre des actions de confinement adaptées à chaque type de menace (ransomware, intrusion, exfiltration).
- Conduire les opérations d'éradication et de rétablissement de manière sécurisée et documentée.

3. Expertise en Investigation Numérique

- Analyser des artefacts forensiques (logs, dump mémoire, image disque, artefacts réseau) pour reconstituer la chronologie d'une attaque.
- Identifier le patient zéro, les vecteurs d'attaque et les techniques utilisées (mapping MITRE ATT&CK).
- Distinguer malware fileless, persistance, lateral movement et exfiltration dans les traces numériques.

4. Conformité, Communication et Amélioration Continue

- Rédiger un rapport d'incident complet et structuré, adapté aux audiences techniques et direction.
- Identifier les obligations de notification aux autorités (CNIL, ANSSI) selon la nature de l'incident.
- Conduire un post-mortem (REX) productif débouchant sur des actions d'amélioration concrètes.

Chapitre 1 : Fondements de la Gestion des Incidents

1. Définition d'un Incident de Sécurité

Un incident de sécurité est tout événement qui compromet ou menace de compromettre la confidentialité, l'intégrité ou la disponibilité d'un actif du système d'information. Cette définition volontairement large englobe des réalités très diverses : l'exécution d'un ransomware qui chiffre les données de production, mais aussi un employé qui copie des fichiers confidentiels sur une clé USB personnelle, un attaquant qui scanne les ports d'un serveur exposé, ou encore une erreur de configuration qui expose des données sensibles sur Internet.

La distinction entre un événement de sécurité et un incident de sécurité est fondamentale. Un événement de sécurité est tout fait observable — une tentative de connexion, une requête DNS vers un domaine suspect, une modification de fichier — qui peut ou non indiquer un problème. Un incident de sécurité est un événement (ou une séquence d'événements) qui a effectivement un impact négatif, ou dont l'impact potentiel justifie une réponse organisée. Ce filtre est le rôle du triage SOC : transformer un flux d'événements bruts en incidents qualifiés nécessitant une action.

2. Classification des Incidents par Niveau de Criticité

Tous les incidents ne méritent pas la même réponse. Une classification par niveau de criticité permet de prioriser les ressources et de calibrer l'urgence de la réponse. Le tableau suivant présente la classification en quatre niveaux la plus couramment adoptée dans les SOC :

Niveau	Criticité	Exemples d'incidents	Délai de réponse cible
P1 — Critique	Impact majeur sur les activités	Ransomware actif, intrusion APT, exfiltration de données massives, compromission AD	Immédiat — cellule de crise < 30 min
P2 — Élevé	Impact significatif, propagation possible	Compte privilégié compromis, malware détecté sur serveur, DDoS impactant	Prise en charge < 1 heure
P3 — Modéré	Impact limité, contenu sur un périmètre restreint	Phishing ayant abouti sur un poste, scan réseau interne, violation de politique	Prise en charge < 4 heures
P4 — Faible	Impact négligeable ou potentiel	Tentative de brute force échouée, alerte IDS isolée, anomalie comportementale mineure	Traitement dans les 24 heures

Cette classification doit être formalisée dans le plan de réponse à incident de l'organisation et connue de tous les acteurs. Elle permet d'éviter deux écueils symétriques : la sur-réaction (déclencher une cellule de crise pour une alerte IDS isolée) et la sous-réaction (traiter un ransomware actif comme un incident de routine). La criticité d'un incident peut également évoluer au cours de sa gestion : un incident initialement classé P3 peut être requalifié P1 si l'investigation révèle une compromission plus étendue que supposée initialement.

3. Le Cycle de Vie d'un Incident — Le Modèle PICERF

La réponse à incident suit un cycle structuré en six phases, souvent désignées par l'acronyme PICERF (Préparation, Identification, Confinement, Éradication, Rétablissement, Feedback). Ce modèle, popularisé par le NIST dans sa publication SP 800-61 (Computer Security Incident Handling Guide), est aujourd'hui la référence mondiale pour la gestion des incidents de sécurité. Le tableau suivant présente chaque phase et ses acteurs clés :

Phase	Nom	Objectif principal	Acteurs clés
1	Préparation	Mettre en place les capacités de détection et de réponse avant tout incident	RSSI, SOC Manager, équipes IT
2	Détection & Analyse	Identifier l'incident, qualifier sa nature et évaluer son impact	Analystes N1/N2, SIEM, EDR

3	Confinement	Empêcher la propagation de la menace sans alerter l'attaquant	Analystes N2/N3, équipes IT
4	Éradication	Supprimer la cause racine de l'incident du système d'information	N2/N3, équipes IT, forensics
5	Rétablissement	Restaurer les services dans un état sécurisé et surveillé	Équipes IT, N2, métiers
6	Post-incident	Capitaliser sur l'expérience pour améliorer les défenses	Toute l'équipe SOC, RSSI, direction

Ces six phases ne sont pas strictement séquentielles. Dans la pratique, un incident complexe peut nécessiter des allers-retours entre les phases : une nouvelle découverte lors de l'éradication peut remettre en cause le périmètre supposé de l'incident et imposer un retour à la phase d'analyse. La gestion d'un incident est un processus itératif guidé par les informations qui émergent progressivement de l'investigation.

Chapitre 2 : Phase 1 — Préparation

1. Pourquoi la Préparation est la Phase la Plus Critique

Paradoxalement, la phase la plus déterminante dans la gestion d'un incident est celle qui précède tout incident : la préparation. Une organisation bien préparée — dotée de plans de réponse documentés, d'équipes formées, d'outils déployés et testés — répondra à une attaque avec une efficacité sans commune mesure avec une organisation qui improvise sa réponse dans l'urgence. Comme en médecine d'urgence, les protocoles doivent être intégrés avant la crise : on n'apprend pas la réanimation cardio-pulmonaire le jour où elle est nécessaire.

La préparation se décline en plusieurs axes complémentaires. La préparation organisationnelle consiste à définir la structure de réponse à incident : qui est responsable de quoi, qui a l'autorité pour prononcer le confinement d'un serveur de production, qui notifie la direction en cas d'incident majeur, qui communique avec les autorités externes. La préparation technique consiste à déployer et maintenir les outils nécessaires : SIEM, EDR, solutions de backup testées, accès forensiques aux systèmes critiques. La préparation humaine consiste à former les équipes, à conduire des exercices de simulation (tabletop exercises, red team) et à maintenir les compétences à jour.

2. Le Plan de Réponse à Incident (PRI)

Le Plan de Réponse à Incident est le document de référence qui formalise les capacités de réponse de l'organisation. Il décrit la politique de gestion des incidents (définitions, classification, périmètre), la structure organisationnelle de réponse (rôles, responsabilités, chaîne d'escalade, astreintes), les procédures opérationnelles pour chaque phase du cycle

PICERF, les playbooks spécifiques par type d'incident (ransomware, phishing, intrusion APT, DDoS), les coordonnées des contacts d'urgence internes et externes (ANSSI, CERT, prestataires forensiques), et les obligations légales de notification.

Un PRI n'a de valeur que s'il est testé régulièrement. Les exercices de simulation d'incident (tabletop exercises) permettent de vérifier que les procédures sont applicables dans les conditions réelles, que tous les acteurs connaissent leur rôle et que les outils fonctionnent comme prévu. Ces exercices révèlent invariablement des lacunes : contacts d'urgence obsolètes, procédures trop vagues pour guider l'action dans l'urgence, dépendances entre systèmes non documentées. Chaque lacune identifiée lors d'un exercice est une vulnérabilité organisationnelle corrigée avant d'être exploitée lors d'un vrai incident.

3. Les Sauvegardes — Premier Rempart contre les Ransomwares

La stratégie de sauvegarde est l'un des éléments de préparation les plus critiques, particulièrement dans le contexte de la menace ransomware. Une sauvegarde efficace repose sur la règle du 3-2-1 : trois copies des données, sur deux supports différents, dont une hors site (ou hors ligne). Le « hors ligne » est désormais crucial : les ransomwares modernes recherchent et chiffrent systématiquement les sauvegardes accessibles depuis le réseau avant de chiffrer les données de production.

La vérification régulière de l'intégrité des sauvegardes et la réalisation de tests de restauration complets sont aussi importantes que les sauvegardes elles-mêmes. Une sauvegarde non testée est une sauvegarde dont on ne connaît pas la valeur réelle. Il est recommandé de tester au minimum trimestriellement la restauration complète d'un système critique depuis la sauvegarde, et de documenter le RPO (Recovery Point Objective — perte de données maximale acceptable) et le RTO (Recovery Time Objective — durée maximale d'indisponibilité acceptable) pour chaque système, afin que les équipes sachent exactement à quoi s'attendre lors d'une restauration en conditions de crise.

Chapitre 3 : Phase 2 — Détection et Analyse

1. Sources et Vecteurs de Détection

La détection d'un incident peut provenir de nombreuses sources, automatisées ou humaines. Les alertes SIEM constituent la source principale dans un SOC mature : les règles de corrélation détectent des patterns suspects et génèrent des alertes qui déclenchent le processus de triage. Les alertes EDR signalent des comportements malveillants directement sur les endpoints, souvent avec une précision supérieure au SIEM pour les attaques fileless ou les techniques d'évasion avancées.

Des sources moins attendues sont aussi fréquentes dans la réalité. Un utilisateur qui signale un comportement anormal de son poste (fenêtres inhabituelles, lenteur soudaine, fichiers inaccessibles) est souvent le premier détecteur d'un ransomware. Un administrateur qui remarque une connexion inhabituelle lors d'une vérification de routine peut identifier une

intrusion avant toute alerte automatique. Les notifications externes — un partenaire prévenant que des emails malveillants semblent provenir de votre domaine, une alerte du CERT-FR sur une campagne ciblant votre secteur, un chercheur en sécurité signalant une vulnérabilité sur vos systèmes — représentent également une part non négligeable des détections réelles.

2. L'Analyse Initiale — Établir le Périmètre de l'Incident

L'analyse initiale vise à répondre à cinq questions fondamentales, communément appelées les « 5W » de l'investigation de sécurité. What — que s'est-il passé exactement ? La nature de l'événement détermine la stratégie de réponse : une intrusion par phishing ne se traite pas comme un ransomware, qui lui-même diffère d'une exfiltration de données. Who — qui est impliqué ? Identifier les comptes utilisateurs, les adresses IP et les systèmes impliqués permet de délimiter le périmètre initial et de prioriser les investigations.

When — quand l'incident a-t-il débuté ? L'horodatage du premier événement suspect est crucial pour délimiter la fenêtre temporelle de l'investigation. Il ne faut jamais supposer que l'alerte SIEM correspond au début de l'intrusion — dans les attaques APT, l'attaquant est présent dans le SI depuis des semaines ou des mois avant d'être détecté. Where — quels systèmes sont affectés ? La cartographie du périmètre de compromission permet de prioriser les actions de confinement. How — comment l'attaquant est-il entré ? Identifier le vecteur d'entrée initial (phishing, exploitation d'une vulnérabilité, credential stuffing, supply chain) est indispensable pour corriger la faille et éviter une réinfection immédiate après l'éradication.

3. La Timeline — Outil Central de l'Investigation

La timeline (chronologie) est la représentation structurée et horodatée de l'ensemble des événements liés à un incident. Elle est construite progressivement au fil de l'investigation, en agrégeant des événements issus de sources multiples : logs SIEM, logs pare-feu, événements EDR, artefacts forensiques des systèmes compromis. Sa construction est l'activité principale de l'analyste N2 lors de la phase d'investigation.

Une timeline bien construite permet de répondre aux questions fondamentales de l'investigation : quel est le patient zéro (premier système compromis) ? Quelle est la séquence exacte des actions de l'attaquant ? Y a-t-il eu des mouvements latéraux vers d'autres systèmes ? Des données ont-elles été exfiltrées, et si oui, lesquelles et vers où ? La timeline est également le document de référence pour le mapping ATT&CK : chaque action identifiée peut être mappée sur une technique de la matrice, permettant de comprendre le mode opératoire global de l'attaquant et d'anticiper ses prochaines étapes.

4. Indicateurs de Compromission — IOC

Lors de l'investigation, l'analyste extrait des indicateurs de compromission (IOC) qui constituent les « empreintes digitales » de l'attaque. Les IOC techniques incluent les hashes MD5/SHA-256 des fichiers malveillants identifiés, les adresses IP des serveurs C2 (Command and Control) avec lesquels le malware communique, les noms de domaines utilisés pour l'infrastructure d'attaque, les URLs de distribution de malware ou d'exfiltration, et les clés de registre ou chemins de fichiers caractéristiques de la persistance.

Ces IOC servent à deux usages immédiats. En priorité, ils alimentent les outils de détection pour rechercher la présence du même attaquant ou du même malware sur d'autres systèmes du SI — une recherche sur l'ensemble du parc via l'EDR permet de découvrir des compromissions supplémentaires non encore détectées. Ensuite, ils sont partagés avec la communauté cybersécurité via des plateformes comme MISP, contribuant à la protection collective contre la même campagne d'attaque.

Chapitre 4 : Phase 3 — Confinement

1. Principes du Confinement

Le confinement est la phase où le défenseur reprend l'initiative. Son objectif est d'empêcher la menace de se propager davantage dans le SI, sans nécessairement l'éliminer immédiatement. Cette nuance est importante : agir trop vite, sans avoir d'abord compris l'étendue de la compromission, risque de masquer des portions de l'attaque encore actives ou d'alerter l'attaquant et de le conduire à accélérer ses actions destructrices.

Le confinement se décline en deux horizons temporels complémentaires. Le confinement à court terme consiste en des actions immédiates visant à interrompre l'activité malveillante en cours : isolation réseau d'une machine compromise, désactivation d'un compte, blocage d'une IP sur le pare-feu. Ces actions sont réalisées dans les minutes ou heures suivant la confirmation de l'incident. Le confinement à long terme consiste en des mesures plus structurelles maintenues pendant toute la durée de l'investigation et de l'éradication : modification des politiques de filtrage, surveillance renforcée des systèmes adjacents, restrictions temporaires d'accès.

2. Stratégies de Confinement par Type d'Incident

Les actions de confinement varient significativement selon la nature de l'incident. Le tableau suivant présente les stratégies adaptées aux types d'incidents les plus fréquents :

Type d'incident	Actions de confinement court terme	Actions de confinement long terme
Ransomware	Isolation réseau immédiate des machines affectées via EDR, déconnexion des partages réseau	Blocage des règles de chiffrement sortant, audit des sauvegardes, reconstruction des machines
Compte compromis	Désactivation du compte dans l'AD, révocation des sessions actives et tokens OAuth	Réinitialisation du mot de passe, audit des actions réalisées, activation MFA
Malware sur poste	Isolation via EDR, blocage du hash malveillant sur tous les endpoints	Analyse forensique du poste, recherche latérale sur les machines ayant communiqué avec le poste
Intrusion serveur	Blocage de l'IP source sur le pare-feu, isolation du serveur compromis	Audit des accès SSH/RDP, revue des crontabs et services installés, scan de rootkits

Exfiltration de données	Blocage du flux sortant au niveau pare-feu, identification et isolation de la source	Analyse du volume exfiltré, notification CNIL si données personnelles, revue des accès DLP
-------------------------	--	--

3. Le Dilemme du Confinement — Sécurité vs Continuité

Le confinement crée inévitablement une tension entre les impératifs de sécurité et les exigences de continuité d'activité. Isoler un serveur ERP en pleine journée de travail pour investiguer une alerte peut interrompre des processus métier critiques et générer des pertes financières immédiates. Ne pas l'isoler laisse potentiellement l'attaquant en position d'élargir sa compromission ou d'exfiltrer des données supplémentaires.

Cette décision ne peut pas être prise unilatéralement par le SOC. Elle requiert une concertation rapide avec le responsable métier de l'application concernée, le RSSI et, pour les décisions les plus impactantes, la direction générale. C'est pour cette raison que la chaîne d'escalade et les processus de décision lors d'un incident doivent être formalisés et connus de tous avant que l'incident ne survienne. Une organisation qui découvre lors d'une crise réelle qu'elle n'a pas de processus de décision clair perd un temps précieux dans des discussions hiérarchiques au moment où chaque minute compte.

4. Préservation des Preuves pendant le Confinement

Le confinement doit être réalisé en préservant autant que possible les preuves numériques nécessaires à l'investigation. Certaines actions de confinement sont destructrices d'informations : éteindre une machine compromise détruit le contenu de la mémoire vive, qui peut contenir des clés de chiffrement, des processus malveillants actifs ou des connexions réseau révélatrices. Avant d'éteindre un système compromis, il est donc recommandé de réaliser un dump mémoire complet (avec des outils comme WinPmem sous Windows ou dd sur Linux).

La notion de chaîne de custody (chain of custody) s'applique à toutes les preuves numériques collectées lors d'un incident. Elle exige que chaque preuve soit documentée au moment de sa collecte (qui l'a collectée, quand, depuis quel système, avec quel outil), que son intégrité soit vérifiable (hash calculé au moment de la collecte et conservé séparément), et que toute manipulation ultérieure soit tracée. Sans cette rigueur, les preuves collectées pourraient être contestées lors d'une procédure judiciaire.

Chapitre 5 : Investigation Forensique Numérique

1. Principes de la Forensique Numérique

La forensique numérique (digital forensics) est la discipline scientifique qui consiste à collecter, préserver, analyser et présenter des preuves numériques de manière à garantir leur intégrité et leur admissibilité lors de procédures légales ou disciplinaires. Dans le

contexte d'un SOC, la forensique intervient principalement lors d'incidents majeurs nécessitant une investigation approfondie : compromission d'un système critique, suspicion d'espionnage industriel, incident avec impact légal.

Le principe fondamental de la forensique numérique est la non-altération de la preuve originale. Toute analyse doit être réalisée sur une copie de la preuve, jamais sur l'original. Les outils forensiques certifiés (FTK Imager, dd avec vérification de hash) permettent de créer des copies bit-à-bit des disques ou des images mémoire, dont l'intégrité est garantie par le hash calculé au moment de la copie. Cette copie, appelée image forensique, est le support de toutes les analyses ultérieures.

2. Principaux Artefacts Forensiques

Les systèmes compromis laissent de nombreuses traces exploitables lors d'une investigation. Le tableau suivant présente les principaux artefacts forensiques et les informations qu'ils permettent d'extraire :

Artefact	Source	Informations exploitables
Dump mémoire vive (RAM)	Volatility, WinPmem	Processus actifs, connexions réseau en cours, clés de chiffrement, malware fileless
Journaux Windows (EVTX)	Windows Event Log	Authentifications, créations de processus, modifications de compte, erreurs système
Journaux Linux (syslog, auth.log)	Fichiers /var/log/	Connexions SSH, commandes sudo, accès aux fichiers, activité cron
Registre Windows	Regedit, KAPE	Persistance (Run keys, services), logiciels installés, derniers fichiers ouverts
Image disque	FTK Imager, dd	Fichiers supprimés, historique des activités, artefacts de navigation, timeline complète
Artefacts réseau (PCAP)	Wireshark, tcpdump	Flux C&C, exfiltration de données, protocoles utilisés, indicateurs de compromission réseau
Préfetch Windows	KAPE, Autopsy	Liste des exécutables lancés, horodatages d'exécution — preuve d'exécution de malware

3. Analyse de la Mémoire Vive

L'analyse de la mémoire vive (RAM forensics) est l'une des techniques les plus puissantes de l'investigation moderne, particulièrement face aux malwares fileless qui ne laissent aucune trace sur le disque. L'outil de référence est Volatility, un framework open source qui permet d'analyser des dumps mémoire Windows, Linux et macOS. Ses plugins permettent de lister les processus actifs au moment du dump et leurs connexions réseau, d'identifier les DLL injectées dans des processus légitimes (technique classique d'évasion), de détecter des processus masqués par des rootkits, d'extraire les hashes de mots de passe depuis le processus LSASS, et de récupérer des artefacts de navigation web, des documents ouverts ou des clés de chiffrement depuis la mémoire.

Un exemple pratique : sur un système suspect, la commande Volatility pstree révèle un processus cmd.exe lancé en enfant de svchost.exe — une configuration anormale qui peut

indiquer une exécution de code via l'exploitation d'un service Windows. La commande netscan liste toutes les connexions réseau actives, permettant d'identifier des connexions vers des serveurs C2 que les logs réseau auraient pu manquer si l'attaquant utilisait un protocole légitime comme HTTPS pour ses communications.

4. Analyse des Journaux et Reconstruction de la Timeline

La reconstruction d'une timeline forensique à partir des journaux systèmes requiert une méthodologie rigoureuse. Sur les systèmes Windows, les journaux EVTX sont analysés avec des outils comme Event Log Explorer ou la solution open source Hayabusa, qui permet de corréler automatiquement les événements et de générer des timelines en format CSV ou HTML. Les Event ID critiques à rechercher systématiquement sont le 4624 (logon réussi), 4625 (logon échoué), 4688 (création de processus), 4698 (tâche planifiée créée — vecteur de persistance classique), 4720 (compte créé), 7045 (service installé) et 1102 (journal d'audit effacé — signal d'alerte majeur indiquant une tentative de dissimulation des traces).

Sur les systèmes Linux, les fichiers `/var/log/auth.log` (authentifications SSH, sudo), `/var/log/syslog` (événements système), `/var/log/apache2/access.log` ou `/var/log/nginx/access.log` (requêtes web) et les fichiers `.bash_history` des utilisateurs constituent les sources primaires. Il faut cependant noter que `.bash_history` peut avoir été effacé ou falsifié par un attaquant : sa valeur probatoire est limitée, contrairement aux journaux syslog qui, lorsqu'ils sont centralisés sur un serveur distant, ne peuvent pas être altérés par l'attaquant ayant compromis la machine locale.

Chapitre 6 : Phase 4 — Éradication

1. Objectifs et Conditions de l'Éradication

L'éradication consiste à supprimer totalement la présence de l'attaquant et de ses outils du système d'information. Elle ne peut être conduite qu'après avoir acquis une compréhension suffisamment complète de la compromission : éradiquer trop tôt, sans avoir cartographié l'ensemble du périmètre affecté, conduit à des éradications partielles — l'attaquant conserve un accès secondaire non détecté et revient via ce backdoor quelques jours après le retour à la normale.

Les conditions préalables à l'éradication sont donc : l'identification complète de tous les systèmes compromis (via la recherche des IOC sur l'ensemble du SI), la compréhension du mécanisme de persistance utilisé par l'attaquant (quelle technique lui permettait de maintenir son accès après redémarrage), et la confirmation que le vecteur d'entrée initial a été identifié et sera corrigé durant l'éradication. Éradiquer sans corriger la vulnérabilité exploitée revient à nettoyer une maison sans en fermer la fenêtre cassée par laquelle le cambrioleur est entré.

2. Techniques d'Éradication

L'éradication des systèmes compromis suit une approche graduelle selon le niveau de compromission constaté. Pour les systèmes faiblement compromis (malware détecté et isolé, sans signe de persistance ou de mouvement latéral), un nettoyage ciblé peut suffire : suppression des fichiers malveillants, suppression des mécanismes de persistance (clés Run, tâches planifiées, services installés), rotation des comptes et mots de passe potentiellement exposés, et application des correctifs.

Pour les systèmes fortement compromis (présence prolongée de l'attaquant, techniques d'évasion avancées, rootkits suspectés), la reconstruction complète depuis une image de référence propre (golden image) est la seule approche fiable. Un système sur lequel un attaquant a opéré pendant plusieurs semaines ne peut jamais être considéré comme entièrement nettoyé par des outils automatiques : les techniques de persistance avancées (UEFI rootkits, implants dans le firmware réseau) peuvent survivre à un formatage standard du disque. Dans ce cas, la reconstruction est la seule garantie d'un état sain.

3. Rotation des Identifiants

La rotation de l'ensemble des identifiants potentiellement exposés est une étape obligatoire de l'éradication, souvent sous-estimée. Lors d'une intrusion, l'attaquant cherche systématiquement à récupérer des identifiants : extraction du fichier SAM ou de la base NTDS depuis l'Active Directory (hashes de tous les comptes du domaine), credential dumping depuis le processus LSASS via Mimikatz, lecture des fichiers de configuration d'applications contenant des mots de passe en clair.

La rotation doit concerner tous les comptes du périmètre compromis, en commençant par les comptes à privilèges (administrateurs locaux, comptes de service, administrateurs de domaine). Dans les cas graves où l'Active Directory est compromis, la rotation peut nécessiter le changement du mot de passe du compte KRBTGT (ce qui invalide tous les tickets Kerberos existants, y compris les Golden Tickets que l'attaquant aurait pu créer) — une opération à réaliser deux fois à intervalles de 10 heures pour garantir l'invalidation complète.

Chapitre 7 : Phase 5 — Rétablissement et Obligations Légales

1. Processus de Rétablissement Sécurisé

Le rétablissement est la phase de retour à la normale — mais pas un retour à l'état antérieur à l'incident, car cet état antérieur comportait les vulnérabilités qui ont permis l'attaque. Le rétablissement doit aboutir à un état amélioré : les systèmes sont restaurés, mais avec les correctifs appliqués, les configurations durcies et les accès assainis. Le tableau suivant détaille les étapes du processus de rétablissement :

Étape	Actions	Points de vigilance
-------	---------	---------------------

1. Validation	Confirmer que la menace est éradiquée avant toute restauration (scan antivirus, vérification des IOC)	Ne jamais restaurer depuis une sauvegarde potentiellement compromise
2. Reconstruction	Réinstaller les systèmes compromis depuis une image de référence propre (golden image)	Documenter la version et la date de l'image utilisée
3. Restauration des données	Restaurer les données depuis la dernière sauvegarde saine vérifiée	Vérifier l'intégrité des sauvegardes (hash) avant restauration
4. Durcissement	Appliquer les correctifs manquants, renforcer les configurations, corriger la cause racine	Ne pas remettre en production sans corriger la vulnérabilité exploitée
5. Tests	Valider le fonctionnement des services restaurés, tester les accès légitimes	Impliquer les équipes métier dans la validation fonctionnelle
6. Surveillance renforcée	Activer une supervision accrue sur les systèmes rétablis pendant 30 à 90 jours	Définir des seuils d'alerte plus sensibles pour la période post-incident

2. Surveillance Renforcée Post-Incident

La période qui suit immédiatement le rétablissement est particulièrement critique. Des études sur les incidents majeurs montrent qu'une proportion significative des réinfections survient dans les 30 jours suivant un premier incident : l'éradication était incomplète, l'attaquant avait un accès de secours non détecté, ou la vulnérabilité initiale n'a pas été totalement corrigée. Il est donc indispensable de maintenir une surveillance renforcée des systèmes rétablis pendant une période de 30 à 90 jours.

Cette surveillance renforcée comprend des seuils d'alerte plus sensibles dans le SIEM pour les systèmes ayant été compromis, une revue quotidienne des logs de ces systèmes par un analyste N2 (plutôt que le triage automatique habituel), et des scans de vulnérabilités hebdomadaires pour s'assurer que les correctifs sont maintenus. Les IOC extraits lors de l'investigation sont également maintenant actifs dans les outils de détection pour identifier toute réapparition des mêmes indicateurs.

3. Obligations de Notification aux Autorités

Plusieurs réglementations imposent des obligations de notification aux autorités en cas d'incident de sécurité affectant des données personnelles ou des infrastructures critiques. Le RGPD (Règlement Général sur la Protection des Données) impose de notifier la CNIL dans un délai de 72 heures à compter de la prise de connaissance d'une violation de données personnelles présentant un risque pour les droits et libertés des personnes. Si le risque est élevé, les personnes concernées doivent également être notifiées sans délai.

La directive NIS2, transposée en droit français, impose aux entités essentielles et importantes de notifier l'ANSSI dans un délai de 24 heures pour un premier rapport préliminaire lors de tout incident ayant un impact significatif, suivi d'un rapport complet dans les 72 heures. Ces délais très courts — notamment les 24 heures NIS2 — soulignent l'importance d'une détection rapide et d'un processus de décision de notification préétabli et testé. Pour les établissements de santé, l'ANS (Agence du Numérique en Santé) doit

également être notifiée pour tout incident significatif affectant les systèmes d'information de santé.

Chapitre 8 : Phase 6 — Post-Incident et Cas Pratique

1. Le Post-Mortem — Capitaliser sur l'Expérience

Le post-mortem (ou REX — Retour d'Expérience) est la réunion structurée organisée après la clôture d'un incident pour analyser ce qui s'est passé, comment l'équipe a répondu, et quelles améliorations peuvent être apportées. C'est la phase la plus souvent négligée — les équipes, épuisées après un incident majeur, ont tendance à vouloir « tourner la page » rapidement — et pourtant la plus précieuse sur le long terme.

Un bon post-mortem est fondé sur un principe de blameless — l'objectif n'est pas de trouver un responsable mais d'identifier les causes systémiques qui ont permis l'incident et les faiblesses dans la réponse. Il se déroule idéalement dans les 5 à 10 jours suivant la clôture de l'incident, en présence de tous les acteurs ayant participé à la réponse. Les questions structurantes sont : quelle est la chronologie complète de l'incident ? Quelle est la cause racine identifiée ? Qu'est-ce qui a bien fonctionné dans notre réponse ? Qu'est-ce qui aurait pu être fait différemment ? Quelles actions correctives concluons-nous ?

2. Actions d'Amélioration Issues du Post-Mortem

Le post-mortem doit impérativement se conclure par un plan d'action concret, avec des responsables désignés et des délais définis. Ces actions peuvent couvrir plusieurs domaines. Sur le plan technique : développement de nouvelles règles de détection dans le SIEM pour couvrir les techniques ATT&CK utilisées par l'attaquant et non détectées automatiquement, déploiement de nouveaux contrôles de sécurité identifiés comme manquants, correction des vulnérabilités qui ont rendu l'attaque possible.

Sur le plan organisationnel : mise à jour des playbooks pour intégrer les enseignements de l'incident, formation des équipes sur les techniques utilisées par l'attaquant, révision des procédures de communication de crise si des dysfonctionnements ont été identifiés. Sur le plan documentaire : mise à jour du plan de réponse à incident, enrichissement de la base de connaissance du SOC avec l'analyse de l'incident, publication d'un rapport de synthèse partageable avec les équipes et la direction.

3. Cas Pratique — Réponse à une Attaque Ransomware

La société LogiTrans SA, entreprise de logistique de 450 salariés, découvre le jeudi 7 mars à 06h32 que ses fichiers partagés sont en cours de chiffrement. L'alerte initiale provient d'un employé de nuit qui constate que tous les documents auxquels il tente d'accéder affichent des extensions inconnues (.lktx) et qu'un fichier README_DECRYPT.txt est présent dans

chaque dossier. Le SOC, contacté immédiatement, active le niveau d'incident P1 et déclenche la cellule de crise.

Phase de détection et analyse : l'analyste N2 interroge le SIEM et l'EDR. Le malware est identifié comme LockBit 3.0, actif depuis 04h17 — soit 2h15 avant la découverte. L'EDR révèle que le processus de chiffrement s'est propagé depuis le poste d'un administrateur (ADMIN-PC-07) via des connexions SMB vers les serveurs de fichiers. L'analyse des logs Active Directory révèle que le compte admin_backup a été utilisé pour se connecter à ADMIN-PC-07 à 04h11, depuis une IP interne appartenant à un serveur web exposé. Ce serveur web devient le patient zéro suspecté.

Phase de confinement : à 07h15, décision est prise d'isoler l'ensemble du segment réseau serveurs via une modification d'urgence des règles pare-feu, et d'isoler individuellement les postes de travail via l'EDR. Le serveur web patient zéro est mis hors ligne. Le compte admin_backup est désactivé dans l'AD. Les serveurs de sauvegarde, vérifiés en urgence, sont confirmés hors ligne et non atteints par le chiffrement — la règle 3-2-1 avec sauvegarde hors ligne a joué son rôle.

Phase d'éradication et rétablissement : l'investigation forensique du serveur web révèle l'exploitation d'une vulnérabilité CVE critique dans le CMS non patché depuis 4 mois, utilisée pour déposer un webshell. Le serveur est reconstruit depuis une golden image. Quarante-deux serveurs de fichiers chiffrés sont reconstruits et leurs données restaurées depuis les sauvegardes hors ligne du mardi soir (RPO : 56 heures de données perdues pour les fichiers non sauvegardés en temps réel). Le retour à la normale complet intervient le lundi suivant — RTO : 4 jours. La CNIL est notifiée dans le délai de 72 heures, aucune donnée personnelle n'ayant été identifiée comme exfiltrée avant le chiffrement.

Post-mortem : le REX identifie trois causes racines. La première est l'absence de processus de gestion des correctifs pour les applications web exposées — le CMS vulnérable n'était suivi par aucun processus de patching. La deuxième est l'absence de segmentation entre le serveur web DMZ et le réseau interne (le serveur web pouvait initier des connexions SMB vers les serveurs de fichiers internes). La troisième est l'absence de surveillance du compte admin_backup hors des horaires d'administration. Trois actions correctives sont décidées avec des délais : déploiement d'un scanner de vulnérabilités web hebdomadaire (J+15), segmentation stricte de la DMZ par modification des règles pare-feu (J+30), et création d'une règle SIEM sur l'utilisation des comptes de service hors horaires (J+7).

Synthèse Générale du Module

Ce cours vous a conduit à travers l'intégralité du cycle de gestion des incidents de sécurité, de la préparation en amont jusqu'au retour d'expérience post-incident, en passant par la détection, l'analyse forensique, le confinement, l'éradication et le rétablissement. La progression adoptée reflète la réalité opérationnelle : chaque phase prépare et conditionne la suivante, et les décisions prises dans les premières heures d'un incident déterminent largement son issue finale.

Trois grandes leçons synthétisent l'ensemble du cours. La première est que la vitesse de réponse est déterminante, mais qu'elle ne doit pas sacrifier la rigueur. Agir vite sans comprendre expose au risque d'une éradication incomplète ou d'un confinement contre-productif. La méthodologie PICERF n'est pas une bureaucratie ralentissant la réponse : c'est le cadre qui garantit que les actions rapides sont aussi les actions justes.

La deuxième leçon est que la forensique numérique est autant un outil de défense qu'un outil d'investigation. Les artefacts collectés lors d'un incident alimentent les règles de détection futures, permettent de comprendre les TTPs de l'attaquant pour anticiper ses prochaines campagnes, et constituent la base de connaissance qui fait progresser la maturité du SOC dans le temps.

La troisième leçon est que la gestion des incidents est un sport collectif. Aucune équipe, aussi compétente soit-elle, ne peut gérer seule un incident majeur : les équipes IT pour le confinement technique, les équipes métier pour les décisions d'arbitrage continuité / sécurité, la direction pour la communication de crise, les équipes juridiques pour les obligations de notification, et parfois les autorités compétentes pour les incidents les plus graves. La qualité des relations et des processus de coordination entre ces acteurs, forgée avant tout incident, est ce qui distingue une réponse maîtrisée d'une crise ingérable.

Glossaire

Terme	Définition
APT	Advanced Persistent Threat — acteur malveillant disposant de ressources importantes (souvent étatiques), opérant sur le long terme avec des techniques furtives et ciblées.
Artefact forensique	Trace numérique laissée par une activité (légitime ou malveillante) sur un système, exploitable lors d'une investigation : logs, fichiers temporaires, entrées de registre, connexions réseau.
C2 / C&C	Command and Control — infrastructure utilisée par un attaquant pour communiquer avec les systèmes compromis (malware, reverse shell, beacon).
Chaîne de custody	Protocole documentant la préservation et le transfert des preuves numériques pour garantir leur recevabilité légale.
CSIRT	Computer Security Incident Response Team — équipe spécialisée dans la réponse aux incidents de sécurité, pouvant être interne ou externe (prestataire).
Eradication	Phase de réponse à incident visant à supprimer totalement la cause racine de l'incident (malware, backdoor, compte compromis) du système d'information.
Fileless malware	Malware qui s'exécute uniquement en mémoire vive sans écrire de fichier sur le disque, échappant ainsi aux antivirus basés sur la signature de fichiers.
Golden image	Image système de référence, propre et durcie, utilisée pour reconstruire rapidement des machines après un incident sans réinstallation manuelle.
IOC	Indicator of Compromise — observable technique (hash, IP, domaine, clé de registre) permettant d'identifier une compromission dans les logs ou sur les systèmes.
Lateral movement	Technique utilisée par un attaquant pour se déplacer progressivement au sein d'un SI après une intrusion initiale, en compromettant des machines supplémentaires.
Patient zéro	Premier système compromis dans la chaîne d'infection, point d'entrée initial de l'attaquant dans le SI.
Persistence	Technique permettant à un attaquant de maintenir un accès à un système compromis après un redémarrage ou une déconnexion (service malveillant, clé Run, tâche planifiée).
Pivot	Technique consistant à utiliser un système compromis comme relai pour attaquer d'autres systèmes du réseau interne.
Ransomware	Logiciel malveillant chiffrant les données des victimes et exigeant une rançon en échange de la clé de déchiffrement.
RTO / RPO	Recovery Time Objective / Recovery Point Objective — indicateurs définissant respectivement la durée maximale d'indisponibilité acceptable et la perte de données tolérable après un incident.
Threat hunting	Approche proactive de recherche des menaces non détectées par les outils automatiques, basée sur des hypothèses formulées à partir de la threat intelligence et du comportement du SI.

